

FUN.XYZ · SECURITY REVIEW

Fun.xyz

Vault Updates.

A security review of Vault Updates.

CLIENT	PROJECT	AUDITORS	AUDIT WINDOW	FINAL REPORT
Fun.xyz	Vault Updates	Guardian	December 9 – December 11, 2025	December 18, 2025

§ 00

Contents.

12 pages — overview, confidence ranking, scope, 3 findings, disclaimer, and about Guardian.

§ 01	Overview	P. 03
§ 02	Confidence Ranking	P. 04
§ 03	Scope & Classifications	P. 05
	Files in Scope	P. 06
§ 04	Findings	P. 07
	Main Review · 3 findings	P. 08
§ 05	Disclaimer	P. 11
§ 06	About Guardian	P. 12

§ 01

Overview.

Guardian reviewed Vault Updates across a single review round. The final report includes 1 Low, 2 Informational findings.

AUDIT FIRM	REPOSITORY
Guardian	fun-xyz/fun-contracts
CLIENT	METHODOLOGY
Fun.xyz	Smart contract · Manual · Main Review
PROJECT	MAIN REVIEW COMMIT
Vault Updates	dc4273ad7b95
PREPARED BY	
Guardian	
AUDIT WINDOW	
December 9 – December 11, 2025	
FINAL REPORT	
December 18, 2025	

1.1 Confidence Ranking

5 / 5

Very High Confidence

Guardian assigns a Confidence Ranking of 5 out of 5, combining finding severity, remediation outcome, and the reviewer’s assessment of latent risk. The full scale is on the next page.

1	2	3	4	5
VERY LOW CONFIDENCE	LOW CONFIDENCE	MODERATE CONFIDENCE	HIGH CONFIDENCE	VERY HIGH CONFIDENCE

1.2 Findings at a Glance

SEVERITY	TOTAL	PENDING	ACK	PARTIAL	RESOLVED
■ Critical	0	0	0	0	0
■ High	0	0	0	0	0
■ Medium	0	0	0	0	0
■ Low	1	0	1	0	0
■ Informational	2	0	2	0	0
All severities	3	0	3	0	0

§ 02

Confidence Ranking.

Guardian assigns a project-level confidence score using the scale below. The ranking combines finding severity, remediation outcome, and the reviewer's assessment of latent risk.

CONFIDENCE RANKING	DEFINITION AND RECOMMENDATION	RISK PROFILE
5 Very High Confidence ASSIGNED	Codebase is mature, clean, and secure. No High or Critical vulnerabilities were found. Follows modern best practices with high test coverage and thoughtful design. Recommendation: code is highly secure at time of audit.	0 High/Critical findings and few Low/Medium severity findings.
4 High Confidence	Code is clean, well-structured, and adheres to best practices. Design patterns are sound and test coverage is strong. Recommendation: suitable for deployment after remediations; consider periodic review with changes.	0-1 High/Critical findings per engagement week and little to no Medium severity findings.
3 Moderate Confidence	Code is functional but shows gaps in defensive programming or test coverage. Recommendation: remediate the findings and re-review the changes before deployment.	Some High/Critical findings, with various Medium severity findings.
2 Low Confidence	Recurring issues suggest systemic gaps rather than isolated mistakes. Recommendation: remediate, then commission a follow-up review at a frozen commit.	Over 6 High and Critical findings across the engagement.
1 Very Low Confidence	The volume and severity of findings indicate the codebase is not ready for production. Recommendation: substantial rework, then a full re-review.	Over 12 High and Critical findings across the engagement.

§ 03

Scope & Classifications.

Guardian reviewed Vault Updates in `fun-xyz/fun-contracts`.

3.1 Severity Matrix

	IMP · HIGH	IMP · MED	IMP · LOW
LIK · HIGH	Critical	High	Medium
LIK · MED	High	Medium	Low
LIK · LOW	Medium	Low	Low

IMPACT · HIGH

Significant loss of assets, harm to a group of users, or core protocol functionality is disrupted.

IMPACT · MEDIUM

Small amount of funds can be lost, or ancillary functionality is affected. Users may experience reduced or delayed receipt.

IMPACT · LOW

Unexpected behavior in some functionality that is notable but does not meet the criteria for higher severity.

LIKELIHOOD · HIGH

Possible with reasonable assumptions that mimic on-chain conditions; cost is low compared to amount gained.

LIKELIHOOD · MEDIUM

Possible only in uncommon cases or requires a large amount of capital relative to disruption caused.

LIKELIHOOD · LOW

Unlikely to ever occur in production.

Files in Scope.

FILE	NSLOC	TOTAL
No files were recorded in scope.		

§ 04

Findings.

Grouped by round. Visible IDs reset by severity within each round, so a finding is named the same way in the report as it was in the channel it was written in.

ID	TITLE	CATEGORY	SEVERITY	STATUS	PAGE
MAIN REVIEW					
L-01	Misleading Tick Functions	Validation	LOW	ACKNOWLEDGED	p. 8
I-01	depositBatch Is Incompatible	Warning	INFORMATIONAL	ACKNOWLEDGED	p. 9
I-02	Some deposits could be DoS'd	DoS	INFORMATIONAL	ACKNOWLEDGED	p. 10

LOW **L-01**

ACKNOWLEDGED

Misleading Tick Functions

CATEGORY	Validation
LOCATION	—
REVIEW	Main Review

— DESCRIPTION

The functions in the VaultDepositoorV2 contract such as `getMinimumDepositForTick`, `validateAmountForTick`, and the validation performed in the `_applyTickRounding` function do not account for the minimum deposit nor the maximum deposit cap that is carried out in the lighter deposit contract.

For each asset, lighter configures an `assetConfig.minDepositTicks` and `assetConfig.depositCapTicks`. For example, the min deposit ticks is 100_000 for ETH, meaning that in fact the minimum deposit is 1e14 (100,000 gwei).

Any deposit that is below the minimum or would put the asset above it's cap is not allowed. This may be misleading for consumers of the view functions within the VaultDepositoorV2 contract and may lead to unexpected failure of bridging & depositing actions.

— RECOMMENDATION

Consider if the minimum and cap should be factored into any of these view functions or even the validation in the `_applyTickRounding` function.

— RESOLUTION

Status: Acknowledged.

INFORMATIONAL **I-01**

ACKNOWLEDGED

depositBatch Is Incompatible

CATEGORY	Warning
LOCATION	Global
REVIEW	Main Review

— DESCRIPTION

The depositBatch function on the AdditionalZkLighter deposit contract is not compatible with Fun's just-in-time amount splicing since it includes several dynamic types in the function signature, with the _amount parameter itself being a dynamic type.

— RECOMMENDATION

Only whitelist the deposit function and not the depositBatch function for invocation on the lighter deposit contract through the wrapper.

— RESOLUTION

Status: Acknowledged.

INFORMATIONAL I-02

ACKNOWLEDGED

Some deposits could be DoS'd

CATEGORY	DoS
LOCATION	Global
REVIEW	Main Review

— DESCRIPTION

The lighter deposit contract has a cap per asset for the amount that can be deposited into the contract. If a deposit through the Fun system would put the lighter contract at or slightly below such a cap, a malicious actor could frontrun this deposit while the cross-chain deposit is in-flight and cause the deposit to instead put the system over the cap causing it to revert.

— RECOMMENDATION

Simply be aware of this risk as it is unlikely and serves no straightforward benefit to the malicious actor, though it may happen benignly in practice.

— RESOLUTION

Status: Acknowledged.

§ 05

Disclaimer.

This report is not, nor should be considered, an "endorsement" or "disapproval" of any particular project or team. This report is not, nor should be considered, an indication of the economics or value of any "product" or "asset" created by any team or project that contracts Guardian to perform a security assessment. This report does not provide any warranty or guarantee regarding the absolute bug-free nature of the technology analyzed, nor do they provide any indication of the technologies proprietors, business, business model or legal compliance.

This report should not be used in any way to make decisions around investment or involvement with any particular project. This report in no way provides investment advice, nor should be leveraged as investment advice of any sort. This report represents an extensive assessing process intending to help our customers increase the quality of their code while reducing the high level of risk presented by cryptographic tokens and blockchain technology.

Blockchain technology and cryptographic assets present a high level of ongoing risk. Guardian's position is that each company and individual are responsible for their own due diligence and continuous security. Guardian's goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies, and in no way claims any guarantee of security or functionality of the technology we agree to analyze.

The assessment services provided by Guardian is subject to dependencies and under continuing development. You agree that your access and/or use, including but not limited to any services, reports, and materials, will be at your sole risk on an as-is, where-is, and as-available basis.

Cryptographic tokens are emergent technologies and carry with them high levels of technical risk and uncertainty. The assessment reports could include false positives, false negatives, and other unpredictable results. The services may access, and depend upon, multiple layers of third-parties.

Notice that smart contracts deployed on the blockchain are not resistant from internal/external exploit. Notice that active smart contract owner privileges constitute an elevated impact to any smart contract's safety and security. Therefore, Guardian does not guarantee the explicit security of the audited smart contract, regardless of the verdict.

§ 06

About Guardian.

Guardian is a smart contract security firm. Every engagement is worked by two independent teams competing on the same scope, each with its own tooling and methods, so no single reviewer's blind spot survives.

\$45B+DIGITAL ASSETS UNDER
REVIEW**200+**

ENGAGEMENTS COMPLETED

500+CRITICAL & HIGH FINDINGS
REPORTED

Reach us at audits@guardianaudits.com.